

AI와 함께 쓰는 첫 논문

로그인 공격의 분산 방식과 속도에 따른 탐지 정책 성능 비교

IP 기반·계정 기반·다중 신호 단계적 대응 방식의 비교

항목	내용
작성자	김태빈
관심 분야	웹 애플리케이션 및 네트워크 보안
작성일	2026-09-14
연구 유형	규칙 기반 모의 로그인 이벤트 실험

결과 한눈에 보기

같은 모의 로그인 원자료를 세 정책에 재생한 결과, 다중 신호·단계적 정책은 네 가지 공격 시나리오를 모두 탐지하면서 공유 네트워크 정상 사용자의 강제 차단율 만들지 않았다.

다중 신호 공격 탐지율	정상 사용자 강제 차단율	저속 공격 첫 대응
100% 공격 4종 평균	0% 공유 네트워크 조건	80.0초 평균 지연 시간

제출용 논문 · 재현 패키지에 포함된 최종본

초록

로그인 공격을 탐지할 때 IP 주소만 볼지, 계정만 볼지, 두 정보를 함께 볼지에 따라 공격 탐지와 정상 사용자 보호 결과가 달라질 수 있다. 본 연구는 집중형 무차별 대입, 빠른 계정 분산 공격, 빠른 IP 분산 공격, 저속 IP 분산 공격, 공유 네트워크 정상 사용의 다섯 가지 모의 로그인 시나리오를 만들고, 이를 IP 단일 정책·계정 단일 정책·다중 신호 단계적 정책에 동일하게 적용했다. 각 시나리오는 10회씩 반복했으며 총 50개 원자료 실행과 150개 정책 평가를 수행했다. 최종 결과에서 IP 단일 정책은 네 가지 공격 시나리오 중 두 가지, 계정 단일 정책도 두 가지를 탐지했다. 다중 신호 정책은 네 가지 공격 시나리오를 모두 탐지했으며, 저속 IP 분산 공격도 평균 80.0초 후 탐지했다. 반면 공유 네트워크 정상 사용에서는 IP 단일 정책이 정상 이벤트의 64.6%를 차단했지만, 계정 단일 정책과 다중 신호 정책에서는 차단이 발생하지 않았다. 이 결과는 본 모의 환경에서 다중 신호·단계적 대응이 공격 유형의 변화에 더 안정적으로 대응하면서 공유 IP 사용자의 강제 차단을 줄였음을 보여 준다. 다만 실제 서비스 로그가 아닌 규칙 기반 모의 데이터이므로 모든 서비스에 같은 정책이 최선이라고 일반화할 수 없다.

1. 서론

온라인 서비스의 로그인 화면은 무차별 대입, 비밀번호 스프레이, 탈취된 계정 정보 재사용과 같은 공격의 대상이 된다. 공격자는 항상 한 IP에서 한 계정을 빠르게 공격하지 않는다. 한 IP가 여러 계정을 조금씩 시도하거나, 여러 IP를 사용해 하나의 계정에 천천히 접근할 수도 있다.

이때 IP만 기준으로 차단하면 IP를 바꾸는 공격을 놓치거나 여러 사용자가 공유하는 네트워크의 정상 사용자를 차단할 수 있다. 계정만 기준으로 차단하면 여러 계정에 한 번씩 시도하는 공격을 놓칠 수 있다. 실제 보안 가이드도 로그인 실패 제한, IP 정보, 접속 시간, 브라우저 정보, 추가 인증 등을 함께 사용하는 방식을 제시한다 [2][3].

연구 질문

로그인 공격의 분산 방식과 속도가 달라질 때 IP 단일 정책·계정 단일 정책·다중 신호 단계적 정책의 탐지율과 정상 사용자 오탐률은 어떻게 달라지는가?

Research workflow



그림 1. 동일한 원자료를 세 정책에 재생해 결과를 비교하는 연구 흐름.

2. 가설 형성 과정

2.1 관심 분야

관심 분야는 웹 애플리케이션 및 네트워크 보안이다. 로그인 경보 자동화와 인증 시스템을 학습하면서, 실제 서비스가 로그인 공격을 어떤 기준으로 구분하는지 확인하고 싶었다.

2.2 검토한 후보 주제

후보 주제	접은 이유
고정 윈도우와 슬라이딩 윈도우 속도 제한 비교	임계값과 시간 창에 따라 결과가 크게 달라져 설정값 비교에 머물 가능성이 높았다.
비밀번호 길이와 무차별 대입 공격 시간 비교	컴퓨터 성능과 비밀번호 목록의 영향을 크게 받고 실제 안전성을 직접 측정하기 어려웠다.
방화벽 ACL 규칙 비교	결과가 허용·차단으로 끝나 정상 사용자 오탐과 공격 유형을 함께 분석하기 어려웠다.
머신러닝 기반 침입 탐지	공개 데이터 정제와 모델 학습에 시간이 많이 필요해 과제 시간 안에 재현하기 어려웠다.
로그인 공격 탐지 정책 비교	모의 로그를 직접 만들 수 있고 공격 유형별 탐지율과 정상 사용자 오탐률을 함께 측정할 수 있어 최종 선택했다.

2.3 AI와의 가설 수정 과정

처음에는 ‘AI가 글쓰기를 도와주는가’처럼 넓은 질문을 검토했지만 무엇을 숫자로 측정할지 분명하지 않았다. 이후 API 속도 제한 비교를 검토했으나 설정값에 따른 차이가 중심이 될 수 있어 로그인 공격 탐지로 범위를 좁혔다. IP만 보는 방식과 계정만 보는 방식은 각각 특정 공격을 놓칠 수 있다는 점을 확인했고, 실제 서비스의 다중 신호·단계적 대응을 단순화한 정책을 추가했다.

처음 네 가지 시나리오로 파일럿을 실행했을 때 빠른 공격에서는 각 단일 정책이 해당 공격에 맞게 작동하는 결과가 주로 나타났다. 이 결과가 너무 직접적인 비교가 되지 않도록, 짧은 시간 창을 벗어나는 저속 IP 분산 공격을 최종 실험 전에 추가했다. 파일럿 원자료와 결과는 data/pilot_v1/에 보존했다.

최종 가설

로그인 공격의 분산 방식과 속도는 방어 정책별 탐지율과 정상 사용자 오탐률에 영향을 주며, IP·계정·시간 정보를 함께 사용해 단계적으로 대응하는 정책은 단일 기준 정책보다 혼합 공격 환경에서 탐지 성능과 정상 사용자 보호의 균형이 좋을 것이다.

2.4 가설의 측정과 반증 조건

- 무엇이 영향을 주는가: 공격의 분산 방식과 속도(집중형, 계정 분산형, 빠른 IP 분산형, 저속 IP 분산형).
- 무엇이 영향을 주는가: 정책별 공격 실행 탐지율, 공격 이벤트 대응률, 정상 사용자 마찰률, 정상 사용자 강제 차단률, 탐지 지연.
- 가설이 틀렸다면: 세 정책의 탐지율이 공격 유형에 따라 거의 달라지지 않거나, 다중 신호 정책이 단일 정책보다 정상 사용자 강제 차단을 더 많이 만들거나, 저속 공격을 탐지하지 못하는 결과가 나온다.
- 데이터 범위: 최종 실험일에 생성한 다섯 시나리오, 시나리오별 10회 반복, 총 50개 실행과 2,100개 로그인 이벤트.

3. 관련 연구

Hofstede 등은 웹 애플리케이션 무차별 대입 공격을 네트워크 데이터로 탐지하는 방법을 제안하고, 실제 웹 호스팅 업체의 약 한 달간 데이터를 사용해 검증했다 [1]. 이 연구는 로그인 공격을 기록된 접속 데이터로 분석할 수 있다는 점을 뒷받침한다.

OWASP는 한 계정에 여러 비밀번호를 시도하는 무차별 대입과 여러 계정에 적은 수의 비밀번호를 시도하는 비밀번호 스프레이를 구분한다. 또한 IP 차단을 유일한 방어 수단으로 사용하지 말고 여러 방어 수단을 단계적으로 적용해야 한다고 설명한다 [2].

NIST SP 800-63B는 실패한 인증 시도를 제한하고, 실패가 증가할수록 대기 시간을 늘리거나 IP 주소·지역·요청 시간·브라우저 정보와 같은 위험 신호를 활용할 수 있다고 제시한다 [3]. Amazon Cognito의 공식 문서도 IP, 사용자 에이전트, 지역 변화 등을 이용해 위험 점수를 만들고 허용·MFA·차단·알림으로 대응하는 제품 방식을 설명한다 [4].

기존 자료가 뒷받침하는 내용은 공격 유형이 서로 다르고 여러 신호를 결합한 단계적 대응이 사용될 수 있다는 점이다. 본 연구가 새로 확인하는 내용은 동일한 모의 원자료에 세 가지 정책을 적용했을 때 공격의 분산 방식과 속도에 따라 탐지율과 정상 사용자 강제 차단률이 실제로 어떻게 달라지는지다.

문헌	출처	이 연구와 연결되는 부분
Hofstede et al. (2017)	Journal / Springer	실제 웹 호스팅 데이터로 공격 탐지를 검증한 근거가 된다.
OWASP (확인일 2026-09-14)	OWASP Cheat Sheet	무차별 대입·비밀번호 스프레이 구분과 IP 단일 의존 회피의 근거가 된다.
NIST SP 800-63B (2025)	NIST 공식 문서	인증 실패 제한과 시간·IP·지역 위험 신호 활용을 뒷받침한다.
Amazon Cognito (확인일 2026-09-14)	AWS 공식 문서	여러 위험 신호로 허용·MFA·차단·알림을 단계 적용하는 실제 서비스 예다.

4. 연구 방법

4.1 원자료 생성

실제 서비스에 요청을 보내지 않고 Python 표준 라이브러리로 모의 로그인 이벤트를 생성했다. 각 이벤트에는 실행 ID, 시각, 계정 ID, IP 주소, 기기 ID, 로그인 결과, 정상·공격 라벨, 시나리오가 포함된다. IP 주소는 문서 예시용 대역을 사용했다.

최종 실험은 다섯 시나리오를 각각 10회 반복해 50개 실행 단위를 만들었다. 각 실행의 무작위 시드는 data/seeds.json에 저장했다. 같은 실행에서 만들어진 원자료는 세 정책에 똑같이 재생했다.

4.2 시나리오와 표본

시나리오	생성 조건	반복
집중형 무차별 대입	한 IP가 한 계정에 약 60초 동안 실패 30회	10회
계정 분산형 비밀번호 스프레이	한 IP가 20개 계정에 각 2회씩 실패	10회
빠른 IP 분산형 공격	20개 IP가 한 계정에 각 2회씩 실패	10회
저속 IP 분산형 공격	20개 IP가 한 계정에 약 16초 간격으로 각 1회씩 실패	10회
공유 네트워크 정상 사용	하나의 IP에서 20명의 사용자가 한 번 실패 한 뒤 성공	10회

4.3 방어 정책

정책	핵심 규칙	대응
P1. IP 단일	같은 IP의 최근 60초 실패 5회 이상	해당 IP 600초 차단
P2. 계정 단일	같은 계정의 최근 60초 실패 5회 이상	해당 계정 600초 차단
P3. 다중 신호	계정 실패, IP별 대상 계정 수, 실패 비율, 서로 다른 IP 수를 60~300초 창에서 결합	지연 → 추가 검증 → 임시 차단

다중 신호 정책은 계정 실패 5회 이상이면 지연을 적용하고, 한 IP의 실패 5회 이상·대상 계정 5개 이상·실패 비율 0.8 이상이면 추가 검증을 요구한다. 최근 300초 동안 한 계정에 5개 이상의 서로 다른 IP가 실패하면 추가 검증을 적용하며, 최근 60초 계정 실패 10회 이상이면 임시 차단한다. 실패 후 성공이 반복되고 실패 비율이 낮은 공유 IP는 IP 조건만으로 차단하지 않는다.

4.4 측정값

측정값	정의
공격 실행 탐지율	공격 실행 중 한 번이라도 지연·추가 검증·차단이 발생한 비율
공격 이벤트 대응률	공격 이벤트 중 대응이 발생한 비율
정상 사용자 마찰률	정상 이벤트 중 지연·추가 검증·차단이 발생한 비율
정상 사용자 강제 차단률	정상 이벤트 중 차단이 발생한 비율
탐지 지연	첫 공격 이벤트부터 첫 대응까지의 시간

4.5 검증 방법

scripts/verify_results.py를 실행해 시나리오별 10회 반복, 총 50개 원자료 실행, 정책별 50개 결과, 총 150개 정책 평가가 존재하는지 확인했다. 또한 모든 원자료 실행 ID가 세 정책에서 빠짐없이 평가되었는지 확인했다. 원자료와 시드는 data/ 아래에, 생성·평가·보고서·검증 절차는 scripts/ 아래에 보존했다.

5. 결과

모든 결과는 최종 원자료 50개 실행과 정책 평가 150개에서 계산했다. 공격 실행 탐지율은 공격 실행 단위에서 한 번이라도 대응이 발생한 비율로 계산했으며, 정상 사용자 강제 차단률은 정상 이벤트에서 차단이 발생한 비율로 계산했다.

Policy outcome matrix

Green = attack detected or no normal-user block · Red = attack missed · Amber = normal-user block

	IP only	Account only	Adaptive
Concentrated	detected	detected	detected
Password spray	detected	missed	detected
Fast distributed	missed	detected	detected
Slow distributed	missed	missed	detected
Shared network	block 64.6%	no block	no block

그림 2. 정책별 시나리오 결과. 공격 시나리오에서는 탐지 여부를, 정상 시나리오에서는 강제 차단 여부를 표시한 결과 행렬.

시나리오	IP 단일	계정 단일	다중 신호
집중형 무차별 대입 탐지율	100.0%	100.0%	100.0%
계정 분산형 비밀번호 스프레이 탐지율	100.0%	0.0%	100.0%
빠른 IP 분산형 공격 탐지율	0.0%	100.0%	100.0%
저속 IP 분산형 공격 탐지율	0.0%	0.0%	100.0%
공유 네트워크 정상 사용 강제 차단률	64.6%	0.0%	0.0%

네 가지 공격 시나리오의 실행 단위 탐지율을 시나리오별로 평균하면 IP 단일 정책은 50.0%, 계정 단일 정책은 50.0%, 다중 신호 정책은 100.0%였다. IP 단일 정책은 계정 분산형 공격을 탐지했지만 IP 분산형 공격과 저속 IP 분산형 공격을 탐지하지 못했다. 계정 단일 정책은 빠른 IP 분산형 공격을 탐지했지만 계정 분산형 공격과 저속 IP 분산형 공격을 탐지하지 못했다.

다중 신호 정책은 네 공격 유형을 모두 탐지했다. 특히 저속 IP 분산형 공격에서 첫 대응까지 평균 80.0초가 걸렸지만, 60초 단일 창만 사용하는 IP 단일·계정 단일 정책은 해당 공격을 탐지하지 못했다.

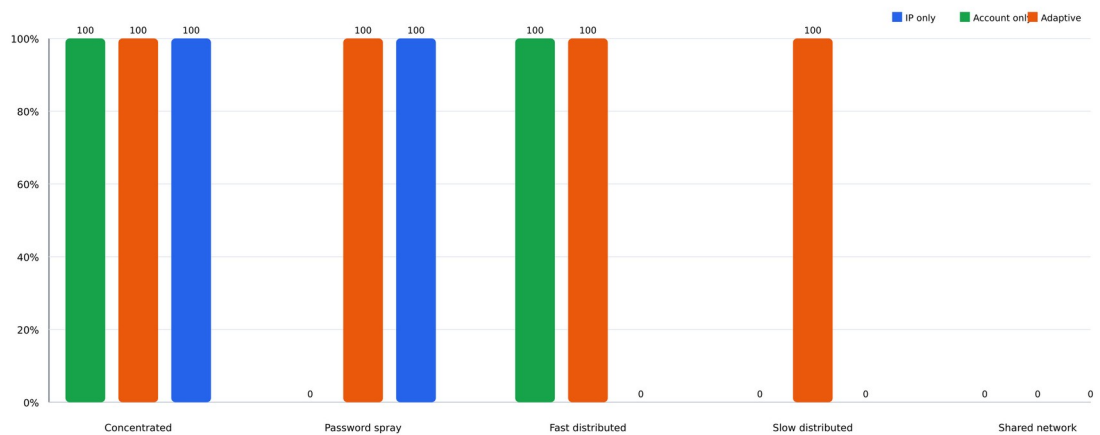


그림 3. 공격 실행 단위 탐지율. 네 가지 공격 시나리오에서 다중 신호 정책은 모두 탐지했다.

Normal-user hard block rate on a shared network



그림 4. 공유 네트워크 정상 사용자 강제 차단률. IP 단일 정책의 강제 차단률이 64.6%로 나타났다.

Mean detection delay for detected attacks

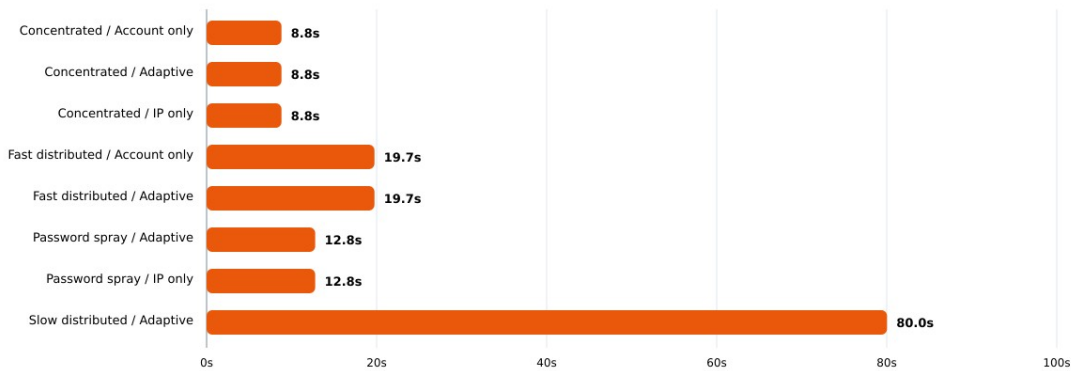


그림 5. 대응이 발생한 공격 시나리오의 평균 첫 대응 시간. 빈 결과는 해당 정책이 공격을 탐지하지 못한 경우다.

정상 사용자 영향에서는 공유 네트워크 정상 사용 시나리오에서 IP 단일 정책이 정상 이벤트의 64.6%를 차단했다. 계정 단일 정책과 다중 신호 정책의 정상 사용자 강제 차단률은 모두 0.0%였다.

6. 논의

결과는 공격의 분산 방식과 속도가 정책 성능에 영향을 준다는 가설의 첫 부분을 지지한다. IP 단일 정책은 여러 계정을 한 IP에서 공격하는 상황에는 효과적이지만, 공격자가 IP를 분산하면 기준에 도달하지 못했다. 계정 단일 정책은 여러 IP가 한 계정을 공격하는 빠른 상황에서는 효과적이지만, 공격 시도가 느려져 60초 창을 벗어나면 탐지하지 못했다.

다중 신호 정책은 IP 단일 정책의 대상 계정 수 조건과 계정 단일 정책의 서로 다른 IP 수 조건을 함께 사용했다. 또한 300초의 긴 시간 창을 사용해 저속 분산 공격을 탐지했다. 이 때문에 네 가지 공격 시나리오를 모두 탐지하면서도, 실패 후 성공이 반복되는 공유 네트워크 정상 사용에서는 차단을 발생시키지 않았다.

6.1 가설과 다르게 보인 결과 및 검토한 가능성

공격 실행 단위의 탐지율만 보면 다중 신호 정책이 네 공격 시나리오에서 모두 100.0%였지만, 저속 IP 분산형 공격의 공격 이벤트 대응률은 75.0%였다. 즉 실행을 한 번 탐지했다는 것과 모든 공격 이벤트를 완화했다는 것은 같지 않다. 이 차이는 한 번의 추가 검증이 발생한 뒤에도 이후 이벤트 모두에 대응하도록 설계하지 않은 정책 규칙과, 실행 단위·이벤트 단위 지표의 정의 차이에서 생겼을 가능성을 검토했다.

정상 사용 시나리오에서는 IP 단일 정책의 정상 사용자 강제 차단률이 64.6%였지만, 공격 실행 탐지 지표는 0.0%였다. 이는 정상 시나리오에 공격 라벨이 없기 때문에 실행 탐지율을 정상 오탐 판단에 사용할 수 없고, 정상 이벤트의 강제 차단률을 별도로 봐야 한다는 뜻이다. IP 단일 정책의 높은 차단률은 공유 네트워크의 여러 정상 사용자가 하나의 IP를 사용하도록 만든 모의 조건과 IP 임계값이 결합한 결과일 가능성도 검토했다.

다중 신호 정책은 저속 공격을 평균 80.0초 후 탐지했으므로 탐지 범위가 넓어진 대신 즉시 차단은 아니었다. 따라서 결과는 다중 신호 정책이 모든 지표에서 항상 우수하다는 뜻이 아니라, 이번 임계값과 모의 시나리오에서 공격 유형을 놓치지 않으면서 정상 사용자 강제 차단을 줄이는 균형이 좋았다는 의미로 해석했다.

다만 이 결과는 다중 신호 정책이 모든 환경에서 항상 우수하다는 뜻은 아니다. 이번 정책은 저속 분산 공격과 공유 네트워크 정상 사용을 구분하도록 설계되었고, 그 규칙과 임계값은 모의 실험에 맞춘 것이다. 실제 서비스에서는 기기 신뢰도, 지역 변화, MFA 사용 가능 여부, IP 평판, 사용자별 평소 행동 등 더 많은 정보가 필요할 수 있다.

7. 연구의 한계

- 실제 서비스의 익명화된 로그가 아니라 연구자가 생성한 모의 로그를 사용했으므로 실제 사용자의 접속 패턴과 공격자의 우회 행동을 모두 포함하지 않는다.
- 공격 시나리오와 임계값을 제한된 수로 설정했으므로 다른 시간 창이나 다른 공격 속도에서는 결과가 달라질 수 있다.
- 다중 신호 정책은 기기 지문, 지역, CAPTCHA, MFA를 실제로 구현하지 않고 계정·IP·실패 비율·시간 창으로 단순화했다.
- 반복 횟수는 시나리오별 10회로 제한했으며, 통계적 일반화보다는 정책 간 차이를 확인하는 기술통계에 목적이 있다.

8. 결론

동일한 모의 로그인 원자료를 비교한 결과, IP 단일 정책과 계정 단일 정책은 각각 특정 공격 유형에는 효과적이었지만 다른 분산 방식의 공격을 놓쳤다. 특히 저속 IP 분산형 공격에서는 두 단일 정책 모두 탐지율이 0.0%였고, 다중 신호 정책만 100.0%의 실행 탐지율을 보였다. 또한 공유 네트워크 정상 사용에서는 IP 단일 정책이 정상 이벤트의 64.6%를 차단했지만 다중 신호 정책은 차단하지 않았다. 따라서 본 실험 범위에서는 IP·계정·시간 정보를 함께 사용하고 대응 수준을 지연·추가 검증·차단으로 나누는 방식이 공격 탐지와 정상 사용자 보호의 균형을 개선했다. 그러나 이 결론은 본 연구에서 만든 모의 데이터와 임계값에 한정되며, 실제 서비스에 적용하려면 더 다양한 로그와 사용자 환경으로 추가 검증해야 한다.

9. 참고문헌

- [1] Hofstede, R., Jonker, M., Sperotto, A., & Pras, A. (2017). Flow-Based Web Application Brute-Force Attack and Compromise Detection. *Journal of Network and Systems Management*, 25, 735–758.
<https://link.springer.com/article/10.1007/s10922-017-9421-4>
- [2] OWASP Cheat Sheet Series. (2026-09-14 확인). Credential Stuffing Prevention.
https://cheatsheetseries.owasp.org/cheatsheets/Credential_Stuffing_Prevention_Cheat_Sheet.html
- [3] National Institute of Standards and Technology. (2025). Digital Identity Guidelines: Authentication and Lifecycle Management, SP 800-63B. <https://pages.nist.gov/800-63-4/sp800-63b.html>
- [4] Amazon Web Services. (2026-09-14 확인). Working with adaptive authentication – Amazon Cognito.
<https://docs.aws.amazon.com/cognito/latest/developerguide/cognito-user-pool-settings-adaptive-authentication.html>

10. 재현 방법

재현 패키지의 프로젝트 루트에서 아래 순서로 실행하면 원자료 생성부터 결과 검증까지 다시 수행할 수 있다. 외부 서비스 호출이나 계정 인증은 필요하지 않다.

```
python3 scripts/generate_data.py
python3 scripts/evaluate_policies.py
python3 scripts/make_report.py
python3 scripts/verify_results.py
```

핵심 산출물은 data/raw_events.csv(원자료), data/seeds.json(재현용 시드), data/run_results.csv(정책별 실행 결과), data/summary.csv(요약 결과), paper/assets/*.png(논문 시각 자료)이다. data/pilot_v1/에는 최종 실험 전에 수행한 파일럿 원자료와 결과를 보존했다.

검증 기준은 시나리오별 10회 반복, 총 50개 원자료 실행, 2,100개 이벤트, 정책별 50개 결과, 총 150개 정책 평가가 존재하는지 확인하는 것이다. 검증 스크립트는 각 실행 ID가 세 정책에서 모두 평가되었는지도 확인한다.

11. AI와 나의 판단

- AI에게 맡긴 일: 후보 주제 확장, 관련 문헌 검색어와 가설 문장 초안, 표·그래프 구성 아이디어.
- 내가 직접 판단한 일: 실행 가능한 주제 선택, 측정값·임계값·반복 횟수 결정, 파일럿 보존과 최종 시나리오 추가 여부 결정.
- 최종 판단: 다중 신호 정책의 결과가 유리하게 보이더라도 모의 데이터와 제한된 임계값에 한정된 결과로 해석하고, 기각될 수 있는 결과와 한계를 함께 기록했다.